

Die Risikomatrix als Instrument der strategischen Datensicherheit: Eine Analyse der Risikobewertung und -klassifizierung

Autor des zugrunde liegenden Konzepts: Mevluet Polat

1. Einleitung

In einer zunehmend digitalisierten Welt, in der Daten als das «Öl des 21. Jahrhunderts» gelten, stellt die Gewährleistung der Datensicherheit eine der zentralen Herausforderungen für moderne Unternehmen dar. Risiken sind im geschäftlichen Alltag allgegenwärtig, doch ihre blosser Identifikation reicht nicht aus. Um die Widerstandsfähigkeit (Resilienz) einer Organisation zu stärken, ist eine systematische Bewertung und Steuerung dieser Risiken unerlässlich. Der vorliegende Artikel befasst sich mit den von Mevluet Polat dargelegten Grundlagen der Risikomatrix und der Risikoklassifizierung.

Dabei wird untersucht, wie das Zwei-Achsen-Modell – bestehend aus Eintrittswahrscheinlichkeit und Schadensausmass – dazu beitragen kann, Objektivität in die Risikobewertung zu bringen, Ressourcen effizient einzusetzen und eine klare Kommunikationsgrundlage zwischen IT-Fachabteilungen und der Geschäftsleitung zu schaffen. Im Fokus steht dabei die praktische Anwendung in der Schweizer Unternehmenslandschaft, insbesondere unter Berücksichtigung des revidierten Datenschutzgesetzes (nDSG).

2. Die theoretischen Grundlagen der Risikobewertung

Risikobewertung ist kein Selbstzweck, sondern bildet die fundamentale Basis für jede fundierte Entscheidung im Bereich der Informationssicherheit. Mevluet Polat betont, dass eine systematische Bewertung notwendig ist, um die oft begrenzten Ressourcen eines Unternehmens dort einzusetzen, wo sie den grössten Schutzwert bieten. In der ökonomischen Realität können nicht alle denkbaren Gefahren gleichzeitig eliminiert werden; daher fungiert die Risikobewertung als Filter- und Steuerungsinstrument, das die Kluft zwischen technischer Notwendigkeit und finanzieller Machbarkeit überbrückt.

2.1 Das Zwei-Achsen-Modell

Das Herzstück des Risikomanagements nach Polat ist die Risikomatrix. Diese basiert auf einem Modell mit zwei Dimensionen:

1. **Eintrittswahrscheinlichkeit:** Wie oft oder mit welcher Wahrscheinlichkeit tritt ein Ereignis innerhalb eines definierten Zeitraums (z. B. ein Geschäftsjahr) ein? Hierbei werden statistische Häufigkeiten gegen subjektive Schätzungen abgewogen.

2. **Schadensausmass:** Welche konkreten negativen Konsequenzen hat das Ereignis für das Unternehmen, falls die Schutzwälle versagen? Dies umfasst nicht nur monetäre Werte, sondern auch immaterielle Güter.

Durch die Kombination dieser beiden Faktoren lässt sich ein Risikowert ermitteln ($R = W \cdot S$). Dieser Wert dient als Indikator für die Dringlichkeit von Massnahmen. Ohne diese mathematisch-logische Differenzierung würden Unternehmen Gefahr laufen, entweder unwichtige Kleinst-Risiken («Parkschäden») überzubewerten oder katastrophale, aber seltene Ereignisse («Black Swans») vollständig zu ignorieren. Das Modell zwingt Entscheidungsträger dazu, sich explizit mit der Wechselwirkung von Häufigkeit und Schwere auseinanderzusetzen.

2.2 Objektivität und Vergleichbarkeit

Ein wesentlicher Vorteil einer standardisierten Risikomatrix ist die Objektivierung von Bedrohungslagen. In vielen Unternehmen werden Risiken oft subjektiv nach «Bauchgefühl» oder aufgrund aktueller Medienberichte bewertet. Ein IT-Leiter sieht technische Schwachstellen eventuell kritischer als ein Finanzchef, der primär die Versicherungsprämien im Blick hat. Polat argumentiert, dass eine standardisierte Matrix eine nachvollziehbare und vergleichbare Einschätzung aller identifizierten Risiken ermöglicht.

Dies schafft eine «Single Source of Truth» und reduziert kognitive Verzerrungen wie den «Availability Bias» (man fürchtet das, worüber gerade in der Zeitung berichtet wird). Durch fest definierte Kriterien wird sichergestellt, dass ein Risiko in der Buchhaltung nach denselben Massstäben gemessen wird wie in der Produktion oder der Logistik. Dies ist die Voraussetzung für eine konsistente Unternehmensstrategie.

3. Dimension 1: Bewertung der Eintrittswahrscheinlichkeit

Die Eintrittswahrscheinlichkeit beschreibt die Frequenz oder die statistische Chance, dass eine Bedrohung innerhalb eines Zeitraums real wird. Sie ist das Mass für die Exposition des Unternehmens gegenüber einer spezifischen Gefahr.

3.1 Skalierung und Klassifizierung

Polat schlägt eine typische fünfstufige Skala vor, die in der Schweizer Praxis weit verbreitet ist:

1. **Sehr unwahrscheinlich:** Das Ereignis tritt statistisch gesehen seltener als alle 10 Jahre ein (z. B. ein verheerendes Naturereignis, das ein hochsicheres Rechenzentrum in den Alpen physisch zerstört).
2. **Unwahrscheinlich:** Ein Eintritt alle 5 bis 10 Jahre ist denkbar, aber es gibt keine aktuellen Anzeichen für eine Häufung.
3. **Möglich:** Das Ereignis könnte alle 2 bis 5 Jahre eintreten (z. B. ein grösserer Hardwaredefekt an einer zentralen Serverkomponente).
4. **Wahrscheinlich:** Ein Eintritt ist etwa einmal pro Jahr zu erwarten. Hierzu zählen oft gezielte, aber noch abwehrbare Angriffe auf die Peripherie.

5. **Sehr wahrscheinlich:** Das Ereignis tritt mehrmals pro Jahr ein oder ist nahezu sicher (z. B. tägliche Phishing-Wellen oder automatisierte Bot-Angriffe auf die Firmenwebsite).

3.2 Die Rolle von Erfahrungswerten und Datenquellen

Um diese Einschätzungen von einer blossen Vermutung zu einer fundierten Analyse zu heben, müssen historische Daten herangezogen werden. Hierzu gehören:

- **Interne Vorfall-Logs:** Wie oft wurde in den letzten 24 Monaten ein Virus im Netzwerk isoliert?
- **Branchenberichte:** Welche Trends meldet das Nationale Zentrum für Cybersicherheit (NCSC) für Schweizer KMU?
- **Vulnerability Scans:** Wie viele bekannte Schwachstellen weist die aktuelle Infrastruktur auf, die von Angreifern ausgenutzt werden könnten?

Beispiel: Ein Schweizer Exportunternehmen stellt fest, dass die Anzahl der Identitätsdiebstahl-Versuche (CEO-Fraud) in der Branche massiv zugenommen hat. Basierend auf diesen Daten stuft es die Eintrittswahrscheinlichkeit von «Möglich» auf «Wahrscheinlich» hoch, was sofortige Schulungsmassnahmen für die Buchhaltung auslöst.

3.3 Dynamik, Monitoring und Dokumentation

Risiken sind fluide Gebilde. Eine Eintrittswahrscheinlichkeit kann durch technologische Sprünge (z. B. Quantencomputing oder KI-gestützte Malware) innerhalb von Wochen von «Unwahrscheinlich» auf «Sehr wahrscheinlich» springen. Daher fordert Polat nicht nur eine punktuelle Aufnahme, sondern eine kontinuierliche Überwachung. Jede Einschätzung muss so dokumentiert werden, dass sie auch zwei Jahre später bei einem Audit nachvollziehbar bleibt. Dies ist besonders im Kontext der Rechenschaftspflicht des nDSG relevant, wo Unternehmen nachweisen müssen, dass sie ihre Hausaufgaben im Risikomanagement gemacht haben.

4. Dimension 2: Bestimmung des Schadensausmasses

Das Schadensausmass beschreibt die Schwere der Folgen, wenn ein identifiziertes Risiko tatsächlich eintritt. Es ist die Antwort auf die Frage: «Wie schlimm wäre es wirklich?»

4.1 Kategorisierung der Schäden nach Polat

Mevluet Polat identifiziert vier Kernkategorien, die ganzheitlich betrachtet werden müssen:

- **Finanzielle Verluste:** Dies umfasst direkte Kosten wie Wiederherstellungsaufwände, entgangene Umsätze während eines Stillstands oder Lösegeldzahlungen bei Ransomware (obwohl von letzteren meist abgeraten wird).
- **Reputationsschäden:** In der Schweiz ist Vertrauen ein zentrales Wirtschaftsgut. Der Verlust von Kundendaten kann zu einer dauerhaften Abwanderung von Klienten führen, was oft schwerer wiegt als der sofortige finanzielle Verlust.
- **Rechtliche Konsequenzen:** Mit dem revidierten nDSG können Bussen von bis zu 250'000

Franken gegen verantwortliche Privatpersonen verhängt werden. Hinzu kommen zivilrechtliche Schadenersatzforderungen betroffener Personen.

- **Betriebliche Ausfälle (Business Continuity):** Wenn die ERP-Software ausfällt, steht die Produktion still. Dies kann Lieferverzögerungen nach sich ziehen, die wiederum Vertragsstrafen auslösen.

4.2 Abstufung des Schadens und Schmerzgrenzen

Die Skalierung erfolgt analog zur Wahrscheinlichkeit:

- **Geringfügig:** Der Schaden ist vernachlässigbar, z. B. kurzzeitiger Ausfall eines unkritischen Informations-Displays im Foyer.
- **Moderat:** Spürbare Auswirkungen, die Überstunden erfordern, aber den Kernbetrieb nicht gefährden.
- **Wesentlich:** Ein ganzer Fachbereich kann einen Tag lang nicht arbeiten; Kunden merken die Verzögerung.
- **Schwerwiegend:** Massive Störung der Hauptprozesse über mehrere Tage; hohe finanzielle Einbussen.
- **Existenzbedrohend:** Das Unternehmen steht vor dem Aus. Beispielsweise, wenn geistiges Eigentum (Patente) gestohlen und veröffentlicht wird oder alle Kundendaten unwiederbringlich verloren gehen.

4.3 Kontextabhängigkeit und Kaskadeneffekte

Das Schadensausmass ist hochgradig individuell. Ein Ausfall der E-Mail-Server für vier Stunden ist für eine Schreinerei ärgerlich, für einen reinen Online-Händler jedoch eine Katastrophe. Zudem müssen Kaskadeneffekte berücksichtigt werden: Ein kleiner technischer Fehler führt zu einem Datenleck, das wiederum einen Reputationsschaden verursacht, der schliesslich in einem massiven Umsatzrückgang endet. Polat plädiert dafür, immer den «Worst-Case-Szenario» innerhalb realistischer Grenzen als Basis für das Schadensausmass zu wählen.

5. Visualisierung und Priorisierung: Die Risikomatrix in der Anwendung

Die grafische Darstellung in der Matrix ist das Werkzeug, das aus Daten Informationen macht. Polat betont die psychologische Wirkung der Visualisierung.

5.1 Farbcodierung als Entscheidungshilfe

Die klassische Ampel-Logik sorgt für sofortige Klarheit:

- **Grüner Bereich:** Akzeptable Risiken. Hier stehen die Kosten für weitere Schutzmassnahmen in keinem Verhältnis zum Nutzen. Monitoring genügt.
- **Gelber Bereich:** Aufmerksamkeit erforderlich. Massnahmen sollten im Rahmen der ordentlichen Budgetplanung berücksichtigt werden.
- **Oranger Bereich:** Erhöhtes Risiko. Es besteht Handlungsbedarf innerhalb eines definierten Zeitraums (z. B. 3–6 Monate).

- **Roter Bereich:** Inakzeptables Risiko. Hier muss sofort interveniert werden. Oft ist ein «Stop-Go»-Entscheid der Geschäftsleitung nötig: Entweder wird das Risiko sofort minimiert, oder der betroffene Prozess wird eingestellt.

5.2 Schwellenwerte und die «Risk Appetite»

Ein zentrales Element im Polat-Konzept ist die Definition der Schwellenwerte. Wo genau die Grenze zwischen Gelb und Orange verläuft, hängt von der «Risk Appetite» (Risikobereitschaft) des Unternehmens ab. Ein junges Start-up wird tendenziell höhere Risiken akzeptieren als eine Privatbank. Die Matrix macht diese implizite Strategie explizit und diskutierbar. Ohne definierte Schwellenwerte bleibt die Matrix ein schönes Bild ohne Konsequenz für das Handeln.

6. Risikomatrix in der Praxis: Workshops und Tools

Die Erstellung einer Risikomatrix darf kein Elfenbeinturm-Projekt der IT-Sicherheit sein. Die Qualität der Matrix hängt direkt von der Qualität des Inputs ab.

6.1 Interdisziplinäre Workshops und Wissens-Silos

Polat empfiehlt dringend interdisziplinäre Workshops. Wenn IT-Spezialisten, Juristen und Abteilungsleiter an einem Tisch sitzen, entsteht ein ganzheitliches Bild. Der IT-Experte kennt die Bedrohung (z. B. SQL-Injection), der Abteilungsleiter kennt den Wert der Daten (z. B. Offerten-Datenbank), und der Jurist kennt die Folgen eines Lecks. Dieser Austausch bricht Silo-Mentalitäten auf und fördert ein gemeinsames Sicherheitsverständnis («Security Culture»).

6.2 Szenarioanalyse als Stress-Test

Statt über abstrakte Risiken wie «Hackerangriff» zu sprechen, sollten konkrete Szenarien entwickelt werden:

- *Szenario A:* «Ein ehemaliger Mitarbeiter hat noch Zugriff auf die Cloud-Daten und löscht wichtige Projektfiles.»
 - *Szenario B:* «Durch ein fehlerhaftes Backup-Konzept sind die Daten der letzten 48 Stunden nach einem Servercrash verloren.»
- Solche Geschichten machen die Risiken greifbar und erlauben eine viel präzisere Einschätzung von Wahrscheinlichkeit und Schaden.

6.3 Softwaretools: Von Excel zu GRC

Während kleine Firmen mit Excel starten, stossen diese bei komplexeren Strukturen an Grenzen. Spezialisierte GRC-Tools (Governance, Risk & Compliance) ermöglichen es, Massnahmen direkt mit Risiken zu verknüpfen, Verantwortlichkeiten zuzuweisen und automatisierte Dashboards für die Geschäftsleitung zu erstellen. Polat weist darauf hin, dass das Tool nur so gut ist wie der Prozess dahinter – eine teure Software rettet kein schlechtes Risikomanagement.

7. Massnahmen und Risikosteuerung: Strategische

Optionen

Nach der Klassifizierung folgt die operative Umsetzung. Polat unterscheidet vier strategische Wege, mit den identifizierten Risiken umzugehen.

7.1 Risikovermeidung (Avoidance)

Hierbei wird die risikobehaftete Aktivität komplett eingestellt.

Beispiel: Ein Schweizer Finanzberater verzichtet darauf, Kundendaten auf privaten Smartphones seiner Berater zu erlauben (Bring Your Own Device), um das Risiko von Datenverlusten durch Diebstahl oder unsichere Apps von vornherein auszuschliessen.

7.2 Risikominderung (Mitigation)

Dies ist die Kernaufgabe der IT-Sicherheit. Man investiert in Schutzmassnahmen, um die Wahrscheinlichkeit oder den Schaden zu senken.

- **Technische Massnahmen:** Einführung einer Multi-Faktor-Authentisierung (MFA) senkt die Wahrscheinlichkeit eines Account-Takeovers massiv.
- **Organisatorische Massnahmen:** Ein Incident-Response-Plan reduziert den Schaden, weil im Ernstfall schneller und koordinierter reagiert wird.

7.3 Risikotransfer (Transfer)

Die finanzielle Last wird auf Dritte verschoben.

Beispiel: Eine Cyber-Versicherung deckt die Kosten für Forensik und Rechtsberatung nach einem Hack. Wichtig: Der operative Schaden (Stillstand) und der Reputationsverlust lassen sich oft nur teilweise transferieren. Auch Outsourcing ist ein Transfer: Man nutzt die Sicherheitsexpertise eines Cloud-Giganten wie Microsoft oder AWS, bleibt aber rechtlich oft in der Mitverantwortung.

7.4 Risikoakzeptanz (Acceptance)

Man entscheidet sich bewusst, nichts zu tun, weil die Kosten der Minderung den potenziellen Schaden übersteigen. Dies ist bei «grünen» Risiken die Standardstrategie. Polat betont jedoch, dass diese Akzeptanz formal dokumentiert werden muss («Management Sign-off»), damit im Schadensfall nachgewiesen werden kann, dass es sich um ein kalkuliertes Risiko handelte.

8. Die Bedeutung für die Kommunikation im Unternehmen

Ein oft unterschätzter Aspekt der Risikomatrix ist ihre Funktion als «Sprachrohr». IT-Sicherheit ist oft hochgradig technisch und für das Management schwer zu greifen. Die Matrix fungiert als Übersetzungshilfe.

8.1 Die Matrix als Verhandlungswerkzeug

Wenn die IT-Abteilung ein Budget für eine neue Firewall beantragt, wird dies oft als Kostenfaktor gesehen. Präsentiert die IT jedoch die Risikomatrix und zeigt auf: «Durch diese Investition von 40'000 Franken schieben wir dieses rote Risiko (Potenzieller Schaden 1 Mio. Franken) in den gelben Bereich», ändert sich die Diskussionsgrundlage fundamental. Es geht nicht mehr um Kosten, sondern um die Vermeidung von Schäden und die Absicherung des Geschäftserfolgs.

8.2 Förderung der Transparenz und Verantwortlichkeit

Die Matrix weist Risiken klare Besitzer (Risk Owner) zu. Es ist nicht mehr «die IT», die für alles zuständig ist. Wenn ein Risiko die Personalabteilung betrifft, muss der HR-Leiter mitentscheiden, wie dieses gesteuert wird. Diese geteilte Verantwortung ist laut Polat der Schlüssel zu einem resilienten Unternehmen. Die Risikomatrix schafft eine Kultur der Ehrlichkeit, in der Schwachstellen nicht versteckt, sondern systematisch abgearbeitet werden.

9. Fazit und Ausblick

Die Risikomatrix und die darauf basierende Risikoklassifizierung nach Mevluet Polat sind unverzichtbare Werkzeuge für ein modernes, proaktives Risikomanagement. Sie bieten eine Struktur, um die Komplexität der digitalen Bedrohungslage zu ordnen und fundierte Entscheidungen zu treffen.

Die zentralen Erkenntnisse lassen sich wie folgt zusammenfassen:

1. **Struktur schlägt Intuition:** Nur durch ein systematisches Modell werden Risiken vergleichbar und steuerbar.
2. **Ressourcenfokus:** Die Matrix verhindert, dass Mittel ineffizient eingesetzt werden. Sie lenkt den Blick auf die «roten» Risiken.
3. **Kulturwandel:** Durch Workshops und gemeinsame Bewertungen wird Risikomanagement von einer reinen IT-Aufgabe zu einer unternehmerischen Kernaufgabe.
4. **Kontinuität:** In einer sich schnell verändernden Bedrohungswelt muss die Risikomatrix ein «lebendes Dokument» sein.

In der Zukunft wird die Integration von automatisierten Bedrohungsinformationen (Threat Intelligence) in die Risikomatrix an Bedeutung gewinnen. Dennoch wird der menschliche Faktor – die fachliche Einschätzung in Workshops und die strategische Entscheidung durch die Geschäftsleitung – das Kernstück des Risikomanagements bleiben. Mevluet Polat liefert mit seinem Konzept das notwendige Fundament, um Organisationen in einer unsicheren digitalen Welt stabil zu halten.

Quellenverzeichnis

- **Polat, Mevluet:** *Risikomatrix und Risikoklassifizierung*. (Grundlagentext zur Risikobewertung in der Datensicherheit).
- **ISO/IEC 27005:** *Information technology — Security techniques — Information security risk*

- management*. (Internationale Norm für IT-Risikomanagement).
- **ISO 31000:** *Risk management — Guidelines*. (Allgemeiner Standard für Risikomanagement).
 - **NCSC (Nationales Zentrum für Cybersicherheit):** *Berichte zur Bedrohungslage in der Schweiz*.
 - **Schweizerisches Bundesgesetz über den Datenschutz (nDSG):** Bestimmungen zur Risikoanalyse und Datensicherheit.
 - **Fink, Dietmar:** *Strategische IT-Risikobewertung*. Springer Gabler, 2021.
 - **Glaubitz, H.:** *Risikomanagement in der IT: Methoden und Werkzeuge zur praktischen Umsetzung*. Hanser Verlag, 2022.